

1/22



File No.: EXP202313871

RESOLUTION OF TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On July 8, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against COMERCIAL GIRONA DE LLIBRES, S.L. (hereinafter, COMERCIAL GIRONA). After notifying the initiation agreement and analyzing the allegations presented, on November 8, 2024, the proposal for resolution was issued, which is transcribed below:

<<

File No.: EXP202313871 (PS/00173/2024)

PROPOSAL FOR RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint with the Catalan Data Protection Authority on June 21, 2023. Since the entity that allegedly may have violated data protection regulations is outside the scope of action of the Catalan Data Protection Authority, in accordance with the provisions of Article 156 of Organic Law 6/2006, of July 19, reforming the Statute of Autonomy of Catalonia, and Article 3 of Law 32/2010, of October 1, of the Catalan Data Protection Authority, the matter was referred to this Agency, having been received on August 8, 2023. The complaint is directed against COMERCIAL GIRONA DE LLIBRES, S.L. with NIF B55192348 (hereinafter, COMERCIAL GIRONA). The reasons on which the complaint is based are as follows:

The complainant states that when registering as a customer at <https://comercialgirona.cat/comandes>, the system returns a confirmation email message that includes both the username (email address used in the registration) and the chosen password.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/22

Along with the complaint, a copy of an email sent from the address clients@comercialgirona.cat to the complainant is provided.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to COMERCIAL GIRONA for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on October 9, 2023, as evidenced by the acknowledgment of receipt in the file.

On November 8, 2023, a response was received by this Agency indicating that it does not consider that there has been a breach of security, as neither the integrity, confidentiality, nor availability of the information made available to the user has been compromised. In this processing, a data processor is involved, from whom the following response was obtained: The passwords entered by the user at the time of registration remained encrypted and that no one other than the user could know what the created password was.

According to the data processor: "The e-commerce software Prestashop, in its version 1.6, when you register as a customer, sends a copy of the registration data to the customer themselves.

This email is only sent to the customer who entered the data. It is not sent to anyone else, nor is a copy kept anywhere.

This is the PHP function that sends the welcome email. It is only sent to the customer's own email

(customer email) and no one else...”

THIRD: On November 8, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: On July 8, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against COMERCIAL GIRONA, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged infringement of Article 32 of the GDPR, classified in Article 83.4.a) of that regulation, in which it was indicated that they had a period of ten days to present allegations.

This initiation agreement, which was notified to COMERCIAL GIRONA in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was recorded on July 22, 2024, as evidenced by the acknowledgment of receipt in the file.

FIFTH: On July 24, 2024, COMERCIAL GIRONA submitted a written request for an extension of the deadline to present allegations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/22

SIXTH: On July 30, 2024, the instructing body of the procedure agrees to extend the deadline requested for a maximum of five days, in accordance with the provisions of Article 32.1 of the LPACAP.

The aforementioned agreement is notified to COMERCIAL GIRONA on July 30, 2024, as evidenced by the acknowledgment of receipt in the file.

SEVENTH: On August 2, 2024, a written submission from COMERCIAL GIRONA is received by this Agency, in due time and form, in which it presents allegations against the initiation agreement, which, in summary, stated that:

- Since the beginning of its activities, it has committed to comply with data protection regulations and has implemented a privacy policy, control processes, and technical and organizational measures to ensure the security of personal data.
- As the data controller, it processes the data confidentially and observes regulatory obligations, with special attention to preventing alteration, loss, unauthorized processing, or access to such data.
- The company details the security measures it has implemented, such as a data protection management model that includes a binding privacy policy and internal procedures to ensure security by design, the use of two-factor authentication for access to customer accounts, and the cessation of sending passwords via email from a certain date, as well as the contract with the designer of its web platform, which also complies with security regulations.

It claims that these security measures are proportional to the risk, which include pseudonymization and encryption, and that it conducts regular assessments of its systems to ensure security. It argues that its responsibility is based on the adoption of reasonable means and not on the infallibility of the measures taken, referring to the jurisprudence of the Supreme Court that supports this perspective.

- The purpose of the processing is solely for access to the website and not for making purchases, and that the data involved are not of special categories of personal nature.

- The company argues that a fine of 20,000 euros would cause serious economic harm, jeopardizing its continuity and affecting its employees, given the economic losses in recent years.

EIGHTH: A list of documents in the procedure is attached as an annex.

From the actions taken in this procedure and the documentation in the file, the following has been established:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/22

PROVEN FACTS

FIRST: On October 6, 2023, this Agency collects evidence of the "Legal Notice and Privacy Policy" from the website <https://comercialgirona.cat/comandes/es/content/3-aviso-legal>.

In this "Legal Notice and Privacy Policy," the following is stated:

"In accordance with the provisions of the General Data Protection Regulation, we inform you that we will process your personal data for the purpose of:

Selling our products online, and informing you about the products or services published on our website.

[...]

We also inform you of the possibility of exercising the following rights regarding your personal data: right of access, rectification, deletion or erasure, limitation, opposition, portability, and withdrawal of consent given, by sending an email to clients@comercialgirona.cat

[...]

The identifying details of the entity are as follows:

Company name: COMERCIAL GIRONA DE LLIBRES SL

NIF: B55192348

Address: Avda. Mas Vila, 142 - 17457 - RIUDELLOTS DE LA SELVA - GIRONA

Phone: 972477695

Email: clients@comercialgirona.cat"

SECOND: The file contains an image of an email message, provided by the complaining party along with the complaint, with the following content:

"Comercial Girona de Llibres <clients@comercialgirona.cat>

To A.A.A.

HELLO A.A.A.,

THANK YOU FOR CREATING A CUSTOMER ACCOUNT AT COMERCIAL GIRONA DE LLIBRES
YOUR ACCOUNT DETAILS AT COMERCIAL GIRONA DE LLIBRES

These are your access details:

Email address: ***EMAIL.1

Password: XXXXXX

You can now place orders in our store: Comercial Girona de Llibres"

According to COMERCIAL GIRONA in its written response dated November 8, 2023, in which it replies to the request made by this Agency:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/22

"On June 21, 2023, a user (complainant) registered on the website of the responsible party (COMERCIAL GIRONA DE LLIBRES) in order to place various orders for textbooks as instructed by their educational center."

THIRD: In the document dated November 8, 2023, COMERCIAL GIRONA describes the user registration process on its website:

"In the registration process, the user registers with the mandatory data requested, all of which are necessary to process and manage the reservation and subsequent purchase of the order. The registration data includes: first and last name, contact email, password (to be chosen by the user), center code to identify the purchase, billing address, and ID number.

- Once the user is registered and successfully activated, the system generates a confirmation email for user registration, containing the access data (username and password) ..."

FOURTH: Regarding the inquiry made by the claimant to COMERCIAL GIRONA, in its document dated November 8, 2023, the respondent states the following:

"...the user contacted the responsible party requesting explanations regarding the sending of the access data confirmation.

- The responsible party immediately contacted the user and explained that no one from the organization or the website developers has access to the users' passwords, as they are encrypted and only the user who registered will have knowledge of them.

- The inquiry was resolved ..."

FIFTH: In the list of data processing activities of the responsible party COMERCIAL GIRONA, provided along with the allegations to the initiation agreement, the following personal data processing is noted:

[...]

Name: Online sales web users

[...]

Responsible: COMERCIAL GIRONA DE LLIBRES, SL

Purpose: Management of online sales to users who purchase a product or service on the company's website.

[...]

Categories of interested parties: Users. Individuals accessing the company's website via the internet.

Data categories: Identification data: First and last name, Tax Identification Number (NIF), postal or email address, phone number. Banking data: For credit card charges or payment direct debits. Others: IP address, username. This includes your digital and electronic signature and the codes or keys you use to access and operate on our website.

[...]"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/22

SIXTH: In the informational letter sent to the AFA, provided by COMERCIAL GIRONA in its allegations to the initiation agreement, the following is stated (original in Catalan):

"TEXTBOOKS 2023/2024

Dear families,

Below, we indicate how to purchase books and materials for the upcoming school year:

ACCESS TO THE WEBSITE

www.comercialgirona.cat/pedidos

Center code: (...)

IMPORTANT: You must register on the website even if you did so last year.

Website access period: from June 15 to July 20

[...]"

SEVENTH: According to the report collected from the AXESOR tool, the entity COMERCIAL GIRONA DE LLIBRES, S.L. is a microenterprise, established in 2014, with a turnover of (...) euros in 2022.

LEGAL GROUNDS

I

Competence

According to the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, and the provisions

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

regulatory provisions issued in its development and, insofar as they do not contradict them, with a subsidiary nature, by the general rules on administrative procedures."

II

Preliminary Issues

In the present case, according to the provisions of articles 4.1 and 4.2 of the GDPR, there is evidence of the processing of personal data, since COMERCIAL GIRONA, as the data controller, carries out the collection, storage, and communication of, among others, the following personal data of individuals: name, email address, and password of customers, among other processing activities.

COMERCIAL GIRONA carries out this activity in its capacity as the data controller, as it is the one who determines the purposes and means of such activity, by virtue of article 4.7 of the GDPR.

Article 32 of the GDPR regulates the security measures that must be adopted to ensure a level of security appropriate to the risk presented by the processing of personal data.

III

Security Measures

Article 32 "Security of Processing" of the GDPR states:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to article 40 or to an approved certification mechanism pursuant to article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law."

In the email sent by COMERCIAL GIRONA to the complainant notifying them of their registration as a customer, in addition to the registration email, the user's password is included.

Regarding the security of email, the "Good Practices Report" from May 2021, CNN-CERT BP02, from the National Cryptologic Center, a service attached to the National Intelligence Center, whose mission is to contribute to the improvement of Spanish cybersecurity, outlines a series of vulnerabilities of email and the various ways in which they can be attacked, as well as security recommendations. In section 4.2 of this Report, "Security of Communications via Email" is described, with the following assertions on pages 37 to 39:

"The protocol involved in this sending process is SMTP. This protocol has been used since 1982, and when it was implemented, security measures such as encryption or authentication of communications were not taken into account. This means that the entire sending process described above would be carried out in plain text, meaning that at any point in the transmission, an attacker could see and manipulate the content of the emails. Due to these shortcomings in SMTP, various technologies and extensions have been developed that allow for the incorporation of security measures to ensure authentication, integrity, and encryption of email communications. Some of the most well-known

technologies are STARTTLS, SPF, DKIM, and DMARC... Although the most well-known email providers such as Google, Yahoo, and Outlook encrypt and authenticate emails using these types of technologies, many organizations continue to use email carelessly. It should also be noted that these technologies must be implemented both at the source and at the destination for them to be utilized. Furthermore, some of these measures are susceptible to attacks. For example, STARTTLS is vulnerable to downgrade attacks, where an attacker in a man-in-the-middle situation can force the TLS negotiation not to take place (it would be enough to replace the STARTTLS string). Even if the TLS communication is successfully established, the mail servers through which the email passes until it reaches its destination would have access to its content. Due to these facts, it is concluded that it is not sufficient to delegate the security of email to the underlying technologies responsible for delivering it to its recipient.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/22

In light of the security shortcomings mentioned above, it is evident that email is not an adequate means to ensure the integrity and confidentiality in the transmission of personal data, posing a risk to the clients of COMERCIAL GIRONA, to whom their password is sent along with the username via email when they register on the website of the aforementioned entity. The fact that the email is only sent to the client who has entered the data does not guarantee that the data cannot be intercepted. On the other hand, sending passwords to the email addresses of COMERCIAL GIRONA's clients means that they can be stored in that medium, which constitutes a practice that may pose a risk to clients, as these passwords, along with their respective usernames, would be vulnerable to any type of cyber attack. It would be of no use for COMERCIAL GIRONA to keep them encrypted, as stated in its response to the transfer of the complaint, when the emails of its clients would have no additional protection.

It should be noted that the GDPR does not establish a list of security measures applicable according to the data being processed, but rather, by virtue of the proactive responsibility principle of Article 5.2 of the GDPR itself, which entails the requirement that the data controller ensures the effective privacy and integrity of the data, both the controller and the processor shall apply technical and organizational measures that are appropriate to the risk involved in the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the controller must be in a position to demonstrate that it has implemented those measures and that they are adequate to achieve the intended purpose.

Moreover, the security measures must be appropriate and proportionate to the identified risk, indicating that the determination of the technical and organizational measures should be carried out taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification process (not audit), assessment, and evaluation of the effectiveness of the measures. In any case, when evaluating the adequacy of the level of security, particular attention shall be paid to the risks presented by the data processing, as a consequence of the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial damage.

In this same sense, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of the processing and apply measures to mitigate them, such as encryption.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

10/22

The measures must guarantee an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation concerning the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly those that may cause physical, material, or immaterial harm.

In light of the above, it must be considered that the technical and organizational measures applied by COMERCIAL GIRONA in the email communication regarding the creation of a customer account by the claiming party do not guarantee an adequate level of security concerning the risk, as email cannot be considered an appropriate means for sending and storing user passwords, and even more so when the user to whom it belongs is sent together.

In accordance with the evidence available at this moment in the proposal for resolution of the sanctioning procedure, it is considered that the known facts could constitute an infringement attributable to COMERCIAL GIRONA for violation of Article 32 of the GDPR.

IV

Classification of the infringement of Article 32

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)" In this regard, the LOPDGDD, in its Article 71 "Infringements," establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a two-year statute of limitations: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following: (...)

f) The failure to adopt those technical and organizational measures that are appropriate to guarantee an adequate level of security concerning the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

V

Sanction for the infringement of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to scale the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR: As circumstances of 83.2 of the GDPR for the purpose of determining the degree of severity of the infringement:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question (paragraph a): The responsibility for the infringement committed by COMERCIAL GIRONA is increased because the purpose of the processing is related to the main activity of the controller.
- The categories of personal data affected by the infringement (paragraph g): Since it concerns the password for identification on a website, it is a data that must be specially protected. Otherwise, any access to this data by unauthorized third parties poses a risk of identity theft of the user using the

COMERCIAL GIRONA website.

It is also considered appropriate to scale the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As an aggravating factor:

- The link of the infringer's activity with the processing of personal data (paragraph b): The business activity carried out by COMERCIAL GIRONA, through the sale of books online, requires continuous processing of personal data of those customers who register on its website.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating what is established in Article 32 of the GDPR, allows for the proposal of a sanction of €20,000 (twenty thousand euros).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/22

VI

Response to the allegations made regarding the initiation agreement

In relation to the allegations made by COMERCIAL GIRONA regarding the initiation agreement, a response is provided to each of them in the order they are presented in their writing:

"FIRST"

According to COMERCIAL GIRONA, since the beginning of its activities, it has committed to comply with data protection regulations and has implemented a privacy policy, control processes, and technical and organizational measures to ensure the security of personal data.

Notwithstanding all these measures implemented for compliance with data protection regulations, until the initiation of the present procedure, COMERCIAL GIRONA had not adopted any specific technical or organizational measures aimed at ensuring an adequate level of security relative to the risk, preventing an email that is automatically sent when a user registers on their website from containing the username and password, despite the fact that the complainant contacted COMERCIAL GIRONA to highlight the error of this circumstance, as described by the respondent in the response to the transfer of the complaint "...the user contacted the Responsible Party asking for explanations regarding the sending of the access data confirmation." The only measure adopted by COMERCIAL GIRONA was to inform the complainant that "no one in the organization or developers of the website has access to users' passwords, as they are encrypted and only the user who registered will have knowledge of them."

For all the above reasons, this allegation is dismissed.

"SECOND: Chronology of the customer registration process:"

In this allegation, COMERCIAL GIRONA explains the customer registration process, with a "double authentication," through the password assigned to the educational center and the username and password through the client's own registration. Finally, for the purchasing process, COMERCIAL GIRONA does not request any banking or personal information.

In response to these arguments, it is first noteworthy that the preparation and sending of the informative letter containing the center code and its subsequent distribution among the families of the students lacks security measures and there are no instructions regarding the educational centers, leaving it to their discretion: "The delivery of this letter to the families is carried out by the center itself in various ways (depending on the method chosen by each center), namely, email, internal school application, instant messaging from the AFA, or in paper format."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/22

Therefore, while the use of the "double password" represents a reinforced measure regarding access

to the COMERCIAL GIRONA website, the lack of security measures in the communication of the center code means that this measure lacks adequate guarantees. Moreover, this center code is known by all families of each center, and there is no guarantee that it cannot be disseminated without any control.

Regardless of the use of the center code, sending the username and password in the same email remains a risk for users registered on the COMERCIAL GIRONA website.

Finally, the argument that no banking or personal information is required during registration on the website contradicts what is stated in the Record of Processing Activities provided by COMERCIAL GIRONA, regarding the processing "online sales web users," where the following categories of data subject to processing are mentioned: Identification: Name and surname, NIF, postal or electronic address, phone number. Banking data: For charges on credit cards or direct debit payments. Others: IP, Username. This includes your digital and electronic signature and the codes or keys you use to access and operate on our website. Additionally, the username and password of the client sent by email together also constitute personal data.

For all the above reasons, this allegation is dismissed.

"THIRD: Implemented Security Measures"

In this section, COMERCIAL GIRONA wishes to outline a series of security measures that are adapted based on the detected risk, having proceeded to eliminate the sending of passwords via email, as well as a series of demonstrative screens highlighting the necessity of having the Center Code to register on the web platform, the existence of an "access validity" to operate with the account, and, lastly, the source code reflecting the encryption process.

Although the company claims that the sending of passwords along with the username has been eliminated, the prior practice of sending them remains relevant for determining the commission of the infringement. In this regard, COMERCIAL GIRONA continued this practice despite acknowledging in their response to the transfer of the complaint that the complainant contacted them to request explanations about this method of access. Consequently, the elimination of the practice of sending username and password in the same email constitutes compliance with the provisional measure imposed in Legal Basis VI of the initiation agreement of the present procedure, and cannot be accepted as an argument to mitigate administrative responsibility.

The screenshots provided illustrate the ideas developed in the "SECOND" allegation, thus the arguments presented in response to

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
14/22

This allegation, as well as the lack of security in the delivery of the "center code," can be brought up regarding the images of the registration process.

Additionally, a screenshot is attached (...).

For all the reasons stated, this allegation is dismissed.

"FOURTH."

COMERCIAL GIRONA presents additional information and documentation regarding security measures by default and by design, in all actions involving new customers, under a risk diversification structure. It reproduces the letter sent to the centers with the center code, provides the contract with the data processor, and includes links to the legal conditions of the tool used on its website.

However, despite these measures, the sending of credentials via email constitutes a violation of Article 32 of the GDPR, which requires the adoption of security measures appropriate to the risk. The lack of adequate measures puts the personal data of customers at risk, and it is considered that the company did not implement sufficient organizational or technical measures to protect sensitive data during transmission, sending the username and password in the same email.

For all the reasons stated, this allegation is dismissed.

"FIFTH.- Communication of the solution to the affected party."

In this allegation, COMERCIAL GIRONA summarizes some of the ideas previously expressed, such as

the use of "two-factor authentication" for access to its website and that the platform does not store customers' banking data. According to COMERCIAL GIRONA, even if this password had been exposed, it would not cause any damage or harm to the data subject, although the concept of zero risk does not exist since there is always an inherent risk that, once measures and guarantees have been applied, is minimized. COMERCIAL GIRONA, in the stages of conception and design of the lifecycle of this processing, defined and applied a series of controls to reduce the probability or impact of the identified risk factors.

In response to this argument, it should be noted that the claimant states in their complaint the following: "I obviously have doubts about the security of this company regarding the banking data used for the purchase of school supplies," which suggests that, in addition to other personal data, financial personal data is also collected during registration on the COMERCIAL GIRONA website. This is confirmed by the provisions in the Record of Processing Activities provided by COMERCIAL GIRONA, concerning the processing "web users online sales," where the following categories of data subject to processing are mentioned, including "banking data: For charges on credit cards or direct debit payments."

Although no economic damage or fraud has materialized directly, the exposure of the username and password in the same email poses a significant risk to the integrity and confidentiality of the data. This fact is particularly relevant considering that the transmission of data via unencrypted emails or through insecure protocols (such as SMTP without TLS encryption) could facilitate the interception of credentials.

As indicated in Recital 83 of the GDPR, security measures must ensure an adequate level of security, including confidentiality. Article 32 of the GDPR establishes the obligation for controllers to implement appropriate technical and organizational measures to avoid such risks, especially in scenarios involving the transmission of sensitive data such as passwords.

Despite COMERCIAL GIRONA's argument that two-factor authentication was used and that the credentials cannot be used alone, the fact that both elements are sent together in a vulnerable medium (email) considerably weakens the security of that data. The GDPR is not limited to the material consequences of the risk but also takes into account the probability and severity of the risk in terms of unauthorized access, reputational damage, and other possible immaterial harms.

Consequently, contrary to what COMERCIAL GIRONA has expressed, the sending of the username and password in a single email without any security measures constitutes a lack of a robust system to prevent risks to personal data, which confirms the company's liability, even without direct damage occurring, due to the lack of diligence in implementing security measures that jeopardize the rights of the data subjects.

For all the reasons stated, this allegation is dismissed.

"In relation to Due Diligence."

In this section, COMERCIAL GIRONA alleges a series of measures implemented, such as two-factor authentication, the record of processing activities, risk analysis, and the contract with the processor regarding the security of the processing, thereby fulfilling the obligation of means established by Article 32 of the GDPR.

COMERCIAL GIRONA is the data controller and, as such, has the obligation to ensure the security of the data throughout the entire process, from its collection to its storage and transmission. The fact that part of the process involves a data processor does not exempt the company from this responsibility, as it must demonstrate that it has implemented, and continues to evaluate, security measures that respond to current and emerging risks, which has not occurred in this case.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/22

The GDPR, in its Article 32, requires that security measures be proportional to the risk and adequate to ensure the confidentiality of the data. Sending both the username and password in the same email poses a serious vulnerability. If such an email were intercepted, an attacker would have access to the

complete credentials, allowing them to impersonate the client on the platform.

A common practice to protect account security is not to send credentials together, and in many cases, it is preferred not to send the password in plain text, but rather through a temporary link for the user to set their own password. The GDPR does not mandate a specific measure, but these are widely used practices as minimum security measures in data processing.

The fact that no immediate negative consequences have occurred does not diminish the seriousness of the breach, nor does it exempt the company from its responsibility for adopting insufficient security measures. The risk of data breach remains present and could cause future harm.

In this regard, the Supreme Court ruling No. 188/2022 referred to by COMERCIAL GIRONA, in its allegations, establishes that, in matters of data protection, security measures are obligations of means and not of results. This means that the company must demonstrate that it has implemented adequate measures at all times, regardless of whether the security breach has had effective consequences or not.

For all the above reasons, this allegation is dismissed.

“SIXTH.”

COMERCIAL GIRONA questions the factors that aggravate its liability in the subject of this procedure, arguing that the purpose of the processing is to validate on the website, which does not allow proceeding with the purchase without the use of the “center code.” It claims that there are no special categories of data involved and that any access to this data by unauthorized third parties does not pose any present or future risk of identity theft of the user, given that the validity of these passwords is limited to only 1.5 months, that is, 45 days.

However, the model of the informative letter attached to the allegations, under the title “TEXTBOOKS 2023/2024,” does explain that the center code is provided to make the purchase of books, along with registration on the website, which must be repeated even if it was done the previous year, so the purpose of the processing is indeed to carry out the purchase of books.

Regarding the category of data processed, the claimant states in their complaint the following: “I obviously have doubts about the security of this company regarding the banking data used for the purchase of school materials,” and in the Record of Processing Activities provided by COMERCIAL GIRONA, concerning the processing “online sales web users,” the categories of data subject to processing are mentioned, including “banking data: for charges on credit cards or direct debit of payments.”

As previously motivated, while the use of the “double password” represents a reinforced measure regarding access to the COMERCIAL GIRONA website, the lack of security measures in the communication of the center code means that this measure lacks adequate guarantees. Furthermore, this center code is known by all families of each center, and there is no guarantee that it cannot be disseminated or used without any control.

Finally, the inaction of COMERCIAL GIRONA must be taken into account. Neither the inquiry made by the claimant nor the transfer of the complaint has prompted the company to modify the registration system on its website; the fact is that until the notification of the initiation agreement of this procedure, it continued to employ insecure methods. This fact suggests a lack of commitment to continuous improvement and the proactive responsibility required by the GDPR.

For all the above reasons, this allegation is dismissed.

“SEVENTH.”

In this allegation, COMERCIAL GIRONA argues that the amount of the sanction is disproportionate given its economic capacity, not having taken into account that its revenues in recent years have been severely affected by the social and health circumstances experienced as a result of the pandemic.

In response to this argument, it should be noted that the amount of the infringement is calculated in accordance with the provisions of Article 83.4.a) of the GDPR, and taking into account the balance of the circumstances contemplated in Articles 83.2 of the GDPR and 76.2 of the LOPDGDD.

The GDPR is clear that security measures must be proportional to the risk, and in this case, the lack of adequate security measures, combined with the practice of sending credentials via email, justifies a sanction. Data protection is not a relative right, and the sanction seeks not only to correct but also to deter future negligent behaviors in the protection of personal data.

For all the above reasons, this allegation is dismissed.

VII

Imposition of measures

If the infringement is confirmed, it is appropriate to impose on the defendant the obligation to adopt adequate measures to adjust its actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor of...

18/22

treatment that the processing operations comply with the provisions of this Regulation, when appropriate, in a certain manner and within a specified time frame...”. The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided for in Article 83.2 of the GDPR.

In this proposal for a resolution of the sanctioning procedure, it is established what the infringement committed has been and the facts that give rise to the violation of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, since it is the data controller who fully knows their organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

However, in this case, regardless of the above, it is appropriate to propose that the resolution orders the complained party to cease the practice of sending the password and user identification in a single email to the users of its website, within 10 business days from the acceptance of the resolution, in accordance with Article 32 of the GDPR, and to send the AEPD the documentation proving its compliance.

It should be noted that in the initiation agreement, this Agency agreed to require the complained party, as a provisional measure, to cease the described conduct. Therefore, the proposed measure is equivalent to making the provisional measure imposed definitive.

It is warned that failure to comply with the possible order to adopt measures imposed by this body in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which could motivate such conduct to open a further sanctioning administrative procedure.

In view of the above, the following

PROPOSAL FOR RESOLUTION

is issued:

That the Director of the Spanish Agency for Data Protection sanctions COMERCIAL GIRONA DE LLIBRES, S.L., with NIF B55192348, for an infringement of Article 32 of the GDPR, classified under Article 83.4.a) of the GDPR, with a fine of €20,000 (twenty thousand euros).

That the Director of the Spanish Agency for Data Protection orders COMERCIAL GIRONA DE LLIBRES, S.L., with NIF B55192348, to adopt definitively the provisional measure imposed in the opening agreement of this sanctioning procedure, in accordance with Article 58.2.d) of the GDPR. Furthermore, in accordance with the provisions of Article 85.2 of the LPACAP, it is informed that it may, at any time prior to the resolution of this procedure, make voluntary payment of the proposed sanction, which will entail a 20% reduction of the amount thereof. With the application of this reduction, the sanction would be established at €16,000 (sixteen thousand euros) and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures. The effectiveness of this reduction will be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative route against the sanction.

In the event that it opts to proceed with the voluntary payment of the amount specified above, in accordance with the provisions of the aforementioned Article 85.2, it must make it effective by depositing it into the restricted account No. IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason, for voluntary payment, for the reduction of the amount

of the sanction. Furthermore, it must send the proof of deposit to the General Subdirectorate of Inspection to proceed to close the file.

By virtue of this, you are notified of the above, and the procedure is made known so that within TEN DAYS you may state whatever you consider in your defense and present the documents and information you deem pertinent, in accordance with Article 89.2 of the LPACAP.

926-070623

R.R.R.

INSTRUCTOR

ANNEX

Index of the file EXP202313871

(...)

>>

SECOND: On November 13, 2024, COMERCIAL GIRONA proceeded to pay the sanction in the amount of €16,000.00, making use of the reduction provided for in the previously transcribed proposal for resolution.

THIRD: COMERCIAL GIRONA has expressly waived any action or appeal in the administrative route against the sanction.

FOURTH: On August 2, 2024, COMERCIAL GIRONA communicated to this Agency the elimination of the practice of sending passwords by email. It provides a certificate issued by the data processor, COMERTIS ECOMMERCE SOLUTIONS, SL with CIF B55192048, dated July 24, 2024, in which it states that on June 23, 2023, at 9:00 a.m., they eliminated the automatic registration email with user and password that Prestashop sent from the website <https://comercialgirona.cat/comandes/>.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/22

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another non-pecuniary sanction but the impropriety of the latter has been justified, voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which

shall be cumulative. The aforementioned reductions must be specified in the notification of the initiation of the procedure, and their effectiveness shall be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction. The percentage of reduction provided in this section may be increased by regulation.”

III

Voluntary payment

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/22

In accordance with the provisions of the aforementioned Article 85 of the LPACAP, the notified resolution proposal allowed for the voluntary payment of the proposed sanction, which would imply a 20% reduction in its amount. With the application of this reduction, the sanction would be set at 16,000.00 euros, and its payment would imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

Following the aforementioned resolution proposal, and before a resolution was issued by this authority, COMERCIAL GIRONA, on November 13, 2024, proceeded to make the voluntary payment, availing itself of the 20% reduction and waiving any action or administrative appeal.

It should be noted that, in accordance with the provisions of the LPACAP, as well as the jurisprudence of the Supreme Court in this matter, the exercise of voluntary payment by the presumed responsible party does not exempt the administration from the obligation to resolve and notify all procedures, regardless of their initiation form. Likewise, Article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure will decide all issues raised by the interested parties and any other matters arising from it.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the commission of the infringements and CONFIRM the sanctions determined in the dispositive part of the resolution proposal transcribed in this resolution.

The sum of the aforementioned amounts yields a total of 20,000.00 euros.

After COMERCIAL GIRONA DE LLIBRES, S.L. made the prompt payment, although without acknowledgment of responsibility, it is proceeded, pursuant to Article 85 of the LPACAP, to reduce the total mentioned by 20%, which results in the final amount of 16,000.00 euros.

SECOND: TO DECLARE the termination of procedure EXP202313871, in accordance with the provisions of Article 85 of the LPACAP.

THIRD: TO CONFIRM, elevating it to definitive, the provisional measure imposed on COMERCIAL GIRONA DE LLIBRES, S.L., consisting of the suspension of the processing of personal data subject to this sanctioning procedure, proceeding to eliminate the practice of sending the automatic registration email with username and password from its website.

FOURTH: TO NOTIFY this resolution to COMERCIAL GIRONA DE LLIBRES, S.L.

FIFTH: In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment to the withdrawal or renunciation of any action or administrative appeal, the present authority accepts the renunciation.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/22

expressly stated by COMERCIAL GIRONA DE LLIBRES, S.L., therefore, the filing of an optional appeal for reconsideration against this resolution is not admissible, all without prejudice to the possibility of resorting to the contentious-administrative jurisdiction.

Consequently, taking into account the provisions of Article 90 of the LPACAP, since no administrative appeal is admissible due to the express waiver, this resolution shall be final and fully enforceable from the moment of its notification.

However, in accordance with the provisions of Article 90.3 a) of the LPACAP, the final resolution in the administrative route may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Agency's Electronic Registry

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded. In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

1414-15012025

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to the vacancy of the Presidency and Deputy Presidency

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es